

API Service Contract

Introduction

CosultIQ is a data-driven platform designed to assist consultancy firms in optimally matching consultants to project requirements. The system centralises consultants' profiles and project specifications and enables intelligent matching through structured data and configurable logic.

This document defines the API Service Contract for demo 1, covering the following functional requirements:

- R1: Authentication and Authorisation
- R2: Consultant Profile Management
- R3: Project Specification Management

The API enables secure communication between the frontend and the backend while enforcing role-based access control and ensuring data integrity.

API Design Design Overview

The ConsultIQ API follows RESTful design principles, ensuring clarity, scalability, and maintainability.

Design Decisions

Architecture: REST API using HTTP methods (GET, POST, PUT, PATCH)

Authentication: JSON web Tokens (JWT)

Authorisation: Role-Based Access Control (RBAC)

Data Format: JSON for all requests and responses

Statelessness: Each request contains all required authentication data

Error Handling: We use standardised error responses across all endpoints

Security Considerations

- User authentication is handled using JWT tokens issued upon login
- JWT tokens have a fixed expiration time set for 8 hours post-login
- Passwords are securely hashed
- Sensitive data, such as the cost to the company, are restricted at API level
- All protected endpoints require a valid bearer token

API Base configuration

Base URL

`https://api.consultiq.co.za/v1`

Authentication Header

`Authorization: Bearer <JWT_TOKEN>`

Standard Error Format

```
{
  "error": "ERROR_CODE",
  "message": "Human-readable message"
}
```

API Endpoints

Authentication (R1)

User Registration

Endpoint: `POST /auth/register`

Description: Creates a new pending user account on behalf of an authorised system user.

Upon successful registration, a verification email is sent to the user to complete account setup, including username/password creation and POPIA consent acceptance.

Request body:

```
{
  "fullName": "Jane Smith",
  "email": "jane.smith@consultiq.com",
  "role": "CONSULTANT"
}
```

Success Response (201 Created)

```
{
  "userId": "uuid",
  "email": "jane.smith@consultiq.com",
  "role": "CONSULTANT",
  "status": "PENDING_VERIFICATION",
  "message": "Verification email sent successfully"
}
```

Error Response (409 Conflict)

```
{
  "error": "EMAIL_ALREADY_EXISTS",
  "message": "A user with this email already exists"
}
```

Error Response (400 Bad Request)

```
{
  "error": "VALIDATION_ERROR",
  "message": "Email address is invalid"
}
```

Complete Registration**Endpoint:** POST /auth/complete-registration

Description: Completes the onboarding process for a registered user by validating the verification token, setting the username and password, and capturing POPIA consent acceptance. Upon successful completion, the user account status is updated from PENDING_VERIFICATION to ACTIVE.

Request body:

```
{
  "token": "verification-token",
}
```

```
"username": "janesmith",
"password": "Password123!",
"acceptedPopia": true
}
```

Success Response (200 OK)

```
{
  "userId": "uuid",
  "username": "janesmith",
  "status": "ACTIVE",
  "message": "Account registration completed successfully"
}
```

Error Response (400 Bad Request)

```
{
  "error": "INVALID_TOKEN",
  "message": "The verification token is invalid or has expired"
}
```

Error Response (400 Bad Request)

```
{
  "error": "INVALID_POPIA_CONSENT",
  "message": "POPIA consent must be accepted to activate the
account"
}
```

Retrieve POPIA Content

Endpoint: GET /popia

Description: Retrieves the POPIA consent page content, including the platform's privacy, data processing, and consent terms that users must review and accept before account activation.

Success Response (200 OK)

```
{
  "title": "POPIA Consent Agreement",

```

```
    "content": "By using ConsultIQ, you consent to the processing  
and storage of your personal information in accordance with the  
Protection of Personal Information Act (POPIA).",  
}
```

Success Response (200 OK)

```
{  
  "error": "POPIA_CONTENT_UNAVAILABLE",  
  "message": "Unable to retrieve POPIA content at this time"  
}
```

User login

Endpoint: POST /auth/login

Description: Authenticates a user with email and password. Returns a JWT on success. Does not specify whether email or password is wrong on failure (R1.1.1, R1.1.3).

Request body:

```
{  
  "email": "jane.smith@consultiq.com",  
  "password": "Password123!"  
}
```

Success Response (200 OK): Login successful. Returns JWT and role-appropriate dashboard redirect hint.

```
{  
  "token": "jwt-token",  
  "expiresIn": 28800,  
  "user": {  
    "id": "uuid",  
    "fullName": "John Doe",  
    "role": "Project Manager"  
  }  
}
```

Error Response (401 Unauthorised): Invalid credentials. The message does not specify whether the email or password was incorrect.

```
{
  "error": "INVALID_CREDENTIALS",
  "message": "The email address or password is incorrect."
}
```

User logout

Endpoint: POST /auth/logout

Description: Invalidates the current user's session token immediately (R1.2.1, R1.2.2).

Success Response (200 OK):

```
{
  "message": "Logout successful"
}
```

Error Response (401 Unauthorised): User is not authenticated.

```
{
  "error": "UNAUTHORISED",
  "message": "Authentication is required"
}
```

Consultant Profile Management (R2)

List All Consultants

Endpoint: GET /consultants

Access Control: Consultant Manager only

Description: Retrieves a paginated list of consultant profiles. Supports search and filtering.

Success Response (200 OK): Paginated list of consultants

```
{
  "page": 1,
  "total": 2,
  "consultants": [
    {
      "id": "uuid",
      "fullName": "Jane Smith",
      "city": "Johannesburg",
      "availabilityStatus": "Available",
      "primarySkills": ["Java", "Spring Boot"]
    }
  ]
}
```

```
}
```

Error Response (401 Unauthorised): Authentication token missing or expired.

```
{
  "error": "UNAUTHORISED",
  "message": "Authentication is required. Please log in."
}
```

Error Response (403 Forbidden): User does not have the required role permission for this action (R1.3.6).

```
{
  "error": "FORBIDDEN",
  "message": "You do not have permission to perform this action."
}
```

Notes:

- Search is case-insensitive (R2.4.1)
- Filters are applied using AND logic (R2.4.2)
- Cost-to-company is not included in list view

Create Consultant Profile

Endpoint: POST /consultants/create

Access Control: Consultant Manager only

Description: Creates a new consultant profile, including skills and certifications. All data is saved in a single transaction.

Request Body:

```
{
  "fullName": "Jane Smith",
  "email": "jane@consultiq.com",
  "city": "Johannesburg",
  "province": "Gauteng",
  "costToCompanyRate": 650,
  "availabilityStatus": "Available",
  "skills": [
    {
      "skillName": "Java",
```

```
        "yearsOfExperience": 4,
        "confidenceLevel": 8
    }
],
"certifications": [
    {
        "certificationName": "AWS Certified Cloud Practitioner",
        "issuingBody": "AWS"
    }
]
}
```

Success Response (201 Created): Consultant profile created successfully.

```
{
  "message": "Consultant created successfully",
  "consultantId": "uuid"
}
```

Error Response (400 Bad Request): Validation error

```
{
  "error": "VALIDATION_ERROR",
  "message": "Duplicate skills are not allowed."
}
```

Error Response (401 Unauthorised): Authentication token missing or expired.

```
{
  "error": "UNAUTHORISED",
  "message": "Authentication is required. Please log in."
}
```

Error Response (403 Forbidden): User does not have the required role permission for this action.

```
{
  "error": "FORBIDDEN",
  "message": "You do not have permission to perform this action."
}
```

Notes:

- Duplicate skills are not allowed (R2.1.6)
- Skills and certifications are saved atomically (R2.1.7)

Get Consultant Profile

Endpoint: GET /consultants/{consultantId}

Access Control: Consultant Manager and/or Admin

Description: Retrieves full details of a consultant profile.

Success Response (200 OK):

```
{
  "id": "uuid",
  "fullName": "Jane Smith",
  "email": "jane@consultiq.com",
  "city": "Johannesburg",
  "province": "Gauteng",
  "costToCompanyRate": 650,
  "availabilityStatus": "Available",
  "skills": [
    {
      "skillName": "Java",
      "yearsOfExperience": 4,
      "confidenceLevel": 8,
      "competencyLevel": "Intermediate"
    }
  ],
  "certifications": []
}
```

Error Response (401 Unauthorised): Authentication token missing or expired.

```
{
  "error": "UNAUTHORISED",
  "message": "Authentication is required. Please log in."
}
```

Error Response (403 Forbidden): User does not have the required role permission for this action.

```
{
  "error": "FORBIDDEN",
  "message": "You do not have permission to perform this action."
}
```

Error Response (404 Not Found): The requested resource does not exist.

```
{
  "error": "NOT_FOUND",
  "message": "The requested resource could not be found."
}
```

Update Consultant Profile

Endpoint: PUT /consultants/{consultantId}

Access Control: Consultant Managers and Consultants (changes made by consultants need approval)

Description: Updates an existing consultant profile. The incoming skill list replaces the existing skills entirely in a single transaction.

Request Body:

```
{
  "fullName": "Jane Smith",
  "email": "jane@consultiq.com",
  "city": "Pretoria",
  "province": "Gauteng",
  "costToCompanyRate": 700,
  "availabilityStatus": "Unavailable",
  "skills": [
    {
      "skillName": "React",
      "yearsOfExperience": 3,
      "confidenceLevel": 7
    }
  ],
  "certifications": []
}
```

Success Response (200 OK):

```
{
  "message": "Consultant updated successfully",
  "consultantId": "uuid"
}
```

Error Response (400 Bad Request):

```
{
  "error": "VALIDATION_ERROR",
  "message": "Invalid input data"
}
```

Notes:

- Skill set is replaced atomically (R2.2.3)
- Competency levels are recalculated on update (R2.2.2)

Preview Derived Competency Level

Endpoint: POST /consultants/competency-preview

Description: Returns a derived competency level based on years of experience and confidence level without saving any data.

Request Body:

```
{
  "yearsOfExperience": 4,
  "confidenceLevel": 8
}
```

Success Response (200 OK): Derived competency level.

```
{
  "competencyLevel": "Beginner"
}
```

Error Response (400 Bad Request):

```
{
  "error": "VALIDATION_ERROR",
  "message": "Invalid input values"
}
```

Notes:

- Used for real-time UI feedback (R2.1.4)
- No data is persisted

Remove Consultant

Endpoint: `DELETE /consultants/{consultantId}`

Access Control: Consultant Manager and Admin

Description: Removes a consultant profile from the system. This action may only be performed by an authorised consultant manager or admin user. The associated consultant account and related profile mappings are removed or deactivated according to business rules.

Success Response (200 OK):

```
{
  "message": "Consultant removed successfully"
}
```

Error Response (404 Not Found)

Project Specification Management (R3)

List All Projects

Endpoint: `GET /projects`

Access Control: Project Manager only

Description: Retrieves a paginated list of project specifications.

Success Response (200 OK): List of project specifications.

```
{
  "page": 1,
  "total": 2,
  "projects": [
    {
      "id": "uuid",
      "projectName": "Banking System Upgrade",
      "clientName": "ABC Bank",
      "city": "Johannesburg",
      "province": "Gauteng",
      "status": "Open",

```

```
        "startDate": "2026-05-01",
        "requiredSkillCount": 3
    }
]
}
```

Notes:

- The list view shows project summary information only

Create Project Specification

Endpoint: POST /projects

Access Control: Project Manager only

Description: Creates a new project specification with required skill requirements. The project is automatically assigned an initial status of Open.

Request Body:

```
{
  "projectName": "Banking System Upgrade",
  "clientName": "ABC Bank",
  "city": "Johannesburg",
  "province": "Gauteng",
  "startDate": "2026-05-01",
  "endDate": "2026-08-30",
  "teamSize": 4,
  "requiredAllocationPercentage": 100,
  "clientBillingBudget": 1200,
  "skillRequirements": [
    {
      "skillName": "Java",
      "minimumCompetencyLevel": "Intermediate",
      "mandatory": true
    }
  ]
}
```

Success Response (200 OK): Project specification created with status Open.

```
{
  "message": "Project created successfully",
  "projectId": "uuid",
  "status": "Open"
}
```

Error Response (400 Bad Request):

```
{
  "error": "VALIDATION_ERROR",
  "message": "Duplicate skill requirements are not allowed."
}
```

Error Response (403 Forbidden):

```
{
  "error": "FORBIDDEN",
  "message": "You do not have permission to perform this
action."
}
```

Get Project Specification

Endpoint: GET /projects/{projectId}

Access Control: Project Manager only

Description: Retrieves the full details of a project specification, including all required skills and mandatory flags.

Success Response (200 OK):

```
{
  "id": "uuid",
  "projectName": "Banking System Upgrade",
  "clientName": "ABC Bank",
  "city": "Johannesburg",
  "province": "Gauteng",
  "startDate": "2026-05-01",

```

```
"endDate": "2026-08-30",
"teamSize": 4,
"requiredAllocationPercentage": 100,
"clientBillingBudget": 1200,
"status": "Open",
"skillRequirements": [
  {
    "skillName": "Java",
    "minimumCompetencyLevel": "Intermediate",
    "mandatory": true
  }
]
```

Error Response (404 Not Found):

```
{
  "error": "NOT_FOUND",
  "message": "Project specification not found"
}
```

Update Project Specification

Endpoint: PUT /projects/{projectId}

Access Control: Project Manager only

Description: Updates an existing project specification, including project details and skill requirements.

Request Body:

```
{
  "projectName": "Banking System Upgrade",
  "clientName": "ABC Bank",
  "city": "Pretoria",
  "province": "Gauteng",
  "startDate": "2026-05-01",
  "endDate": "2026-09-15",
  "teamSize": 5,
  "requiredAllocationPercentage": 100,
  "clientBillingBudget": 1300,
```

```
"skillRequirements": [  
  {  
    "skillName": "Java",  
    "minimumCompetencyLevel": "Expert",  
    "mandatory": true  
  },  
  {  
    "skillName": "React",  
    "minimumCompetencyLevel": "Intermediate",  
    "mandatory": false  
  }  
]  
}
```

Success Response (200 OK):

```
{  
  "message": "Project updated successfully",  
  "projectId": "uuid"  
}
```

Error Response (400 Bad Request)

```
{  
  "error": "VALIDATION_ERROR",  
  "message": "Invalid project input data"  
}
```

Error Response (403 Forbidden)

```
{  
  "error": "FORBIDDEN",  
  "message": "You do not have permission to perform this action"  
}
```


Update Project Status

Endpoint: PATCH /projects/{projectId}/status

Access Control: Project Manager only

Description: Updates the status of a project specification.

Request Body:

```
{
  "status": "In Progress"
}
```

Success Response (200 OK)

```
{
  "message": "Project status updated successfully",
  "projectId": "uuid",
  "status": "In Progress"
}
```

Error Response (400 Bad Request):

```
{
  "error": "INVALID_STATUS",
  "message": "Invalid project status"
}
```

Error Response (403 Forbidden)

```
{
  "error": "FORBIDDEN",
  "message": "You do not have permission to perform this action"
}
```